Proyecto final Python para Ciencia de Datos

Franco Purtscher 5634307-8

Introducción:

En este trabajo se utilizará una base de datos sintética extraída de Kaggle, que contiene información sobre intentos de ciberataques a empresas. Con ella intentaremos conocer y analizar estos ataques; como y donde se llevan a cabo, que particularidades tienen, que patrones existen, entre otras cosas. Y también observar el hecho desde el lugar de la víctima, sus posibles reacciones y sus consecuencias.

Para ello, se aplicarán medidas de resumen, tablas, gráficos, y entrenaremos algunos modelos de machine learning para predecir diferentes aspectos de estos ataques.

Si bien la ciberseguridad es un tema muy importante, el cual se debe conocer y enfatizar para evitar posibles graves consecuencias, que lo convierte en un tema muy interesante para investigar; el objetivo principal de este trabajo es explorar, analizar datos, aplicar técnicas estadísticas, no sacar conclusiones sobre la ciberseguridad real.

Datos:

Como se mencionó en la introducción, el dataset fue creado artificialmente de manera realista, sin ningún tipo de información personal.

Cada fila refiere a un intento de ciberataque diferente, del cual se contiene toda la información, desde el primer momento en que se intenta hasta las consecuencias finales en la víctima.

Columnas: Podemos agrupar las columnas del dataset de la siguiente manera

Grupo	Variables
Identificación y fecha	`Incident_ID`, `Timestamp`, `Hour`, `DayOfWeek`, `Month`, `Business_Hours`, `Weekend`
Características de la Empresa	`Industry`, `Country`, `Company_Size`, `Employee_Count`, `Compliance`, `Vendor_Count`, `SOC_Team_Size`
Seguridad ante ataques	`Firewall`, `MFA`, `EDR`, `IDS`, `Security_Training`, `Password_Policy`, `Security_Maturity`, `Security_Audit_Score`
Posibles vulnerabilidades	`Patch_Age_Days`, `Open_Vulnerabilities`, `CVSS_Score`, `Internet_Exposed`, `ThirdParty_Risk`, `Insider_Risk`

Grupo	Variables
Comienzo del ataque	`Attack_Vector`, `Threat_Actor`, `Attack_Complexity`, `Zero_Day`, `Phishing_Click`
Progresión del ataque	`Credential_Stolen`, `Privilege_Escalation`, `Lateral_Movement`, `Persistence`, `Data_Encrypted`, `Attack_Stage`
Consecuencias	`Data_Exfiltration_GB`, `Detection_Time_Min`, `Response_Time_Min`, `Downtime_Hours`, `Records_Compromised`, `Financial_Loss_USD`, `Recovery_Cost_USD`
Resultado	`Attack_Success`, `Cyber_Risk_Score`, `Risk_Level`, `Incident_Severity`

Principal información del dataframe:

```
Filas: 100500
Columnas: 50
Tipos de columnas:
int64      25
str        14
float64    11
Cantidad de ataques ('Incident_ID'): 100000
```

Vemos que el dataframe tiene 100500 filas pero 100000 `Indicent_ID` de ataques distintos, es decir, contiene 500 filas duplicadas.

Las eliminamos y contamos nuevamente:

```
Filas: 100000
Cantidad de ataques ('Incident_ID'): 100000
```

```
Cantidad de datos faltantes por columna:
Recovery_Cost_USD     70594
Compliance            42772
Financial_Loss_USD     5006
Detection_Time_Min     3147
Company_Size              0
Employee_Count            0
...                       0
```

Entonces tenemos una base de datos con 100000 ataques diferentes y 50 variables que caracterizan cada uno de ellos. De estas 50, tenemos 25 númericas discretas (int64), 11 continuas (float64) y 14 cualitativas (str). Debemos tener en cuenta que algunas de las 25 discretas, son binarias, que valen 1 si la observación cumple con esa variable, y 0 en caso contrario. Además, solamente cuatro columnas tienen datos faltantes. Trataremos con ellos al momento de utilizar dichas columnas.

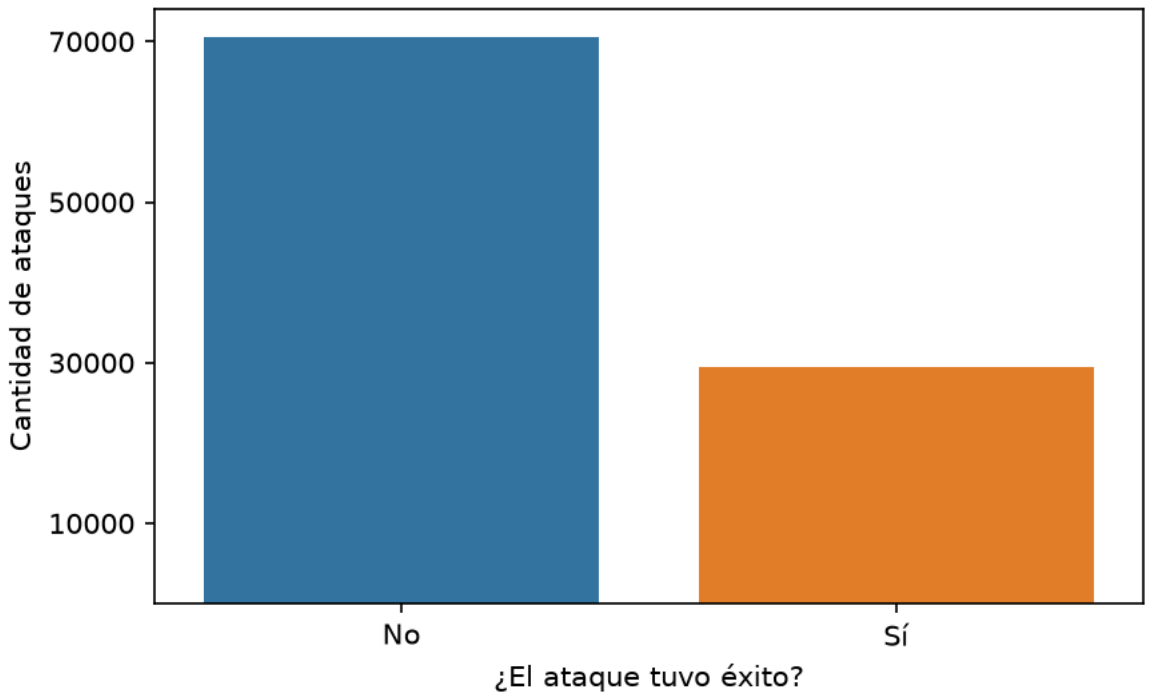
Las variables de respuesta o interés de este analisis son:

- `Attack_Success` que indica si el ataque tuvo éxito (1) o no (0)
- `Cyber_Risk_Score` que numera del 1 al 100 cada ataque según su nivel de riesgo.

Distribución de variables de interés

Frecuencia de `Attack_Succes`:

```
Attack_Success
0    70594
1    29406
Name: count, dtype: int64
```

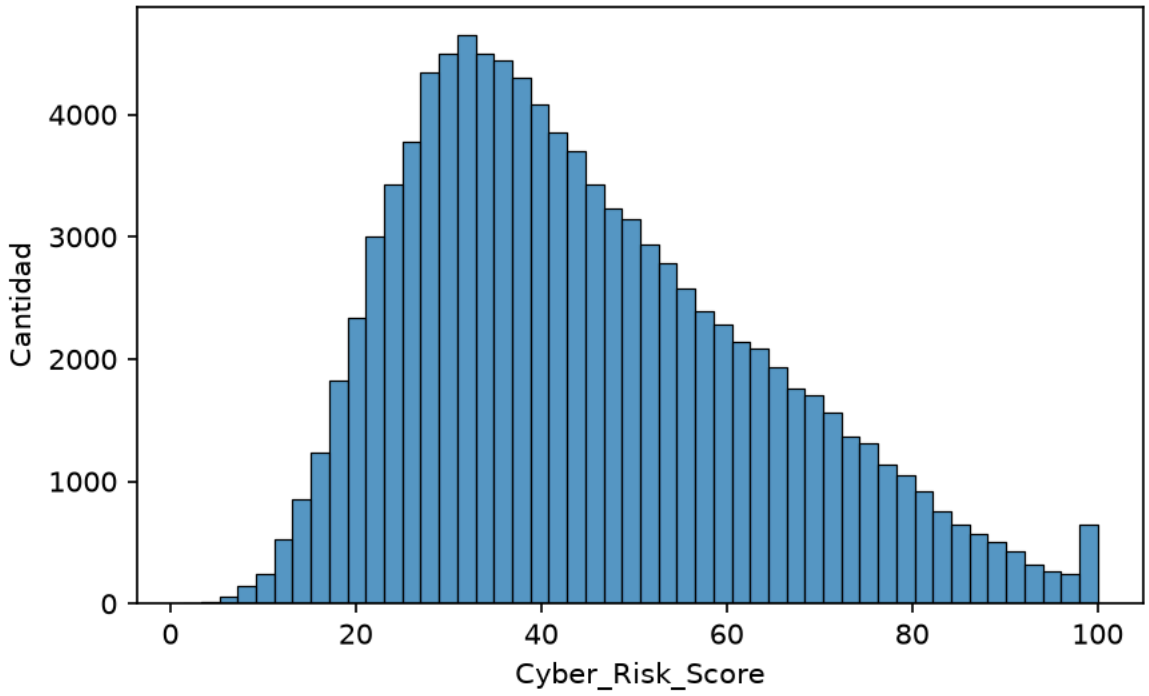


Vemos que de los 100000 ataques, 70594, fracasó y los 29406 casos restantes efectivamente tuvieron éxito.

El gráfico de barras nos permite visualizar la gran diferencia en las frecuencias, habiendo más del doble de observaciones de una categoría con respecto a la otra. Evidencia un dataset desbalanceado.

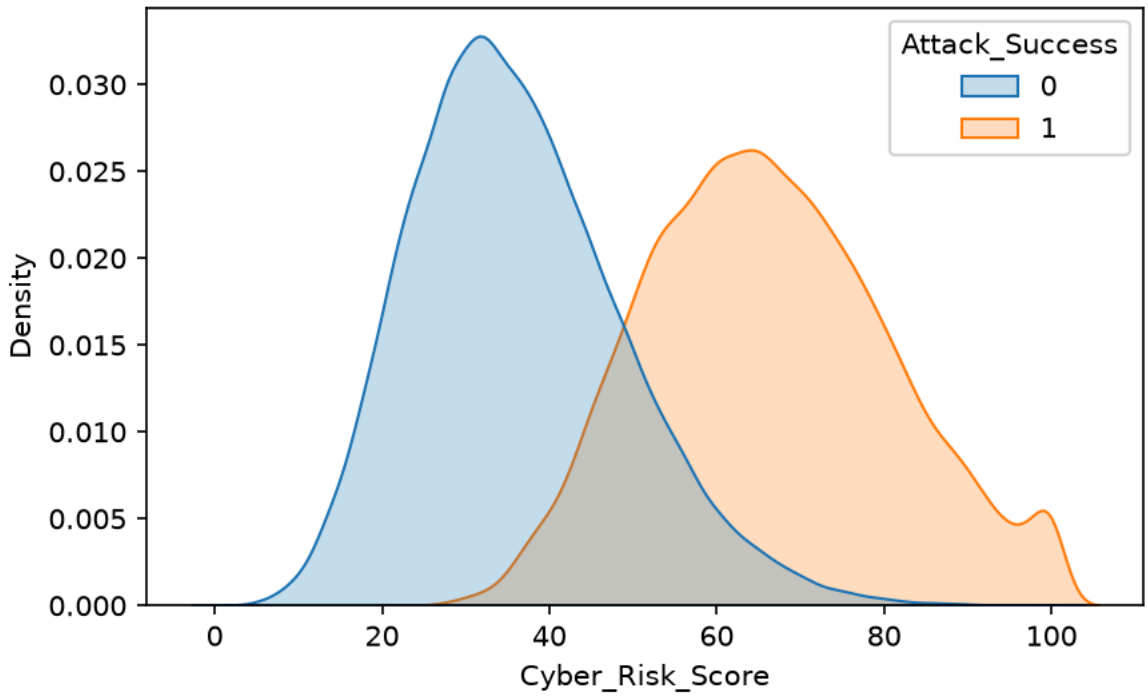
Distribución `Cyber_Risk_Score`:

```
count    100000.000000
mean         45.005120
std          19.047731
min           1.337935
25%          30.387444
50%          41.635008
75%          57.437351
max         100.000000
Name: Cyber_Risk_Score, dtype: float64
```



El nivel de riesgo del ataque observamos que tiene una distribución, con media 45 y mediana 41.6, asimétrica a la derecha, donde además el tercer percentil es 57.4 y el máximo 100. La gran concentración de los datos lo vemos en el pico de la curva entre 25 y 45 de puntaje de riesgo.

También se destaca el último intevalo que rompe con el patrón decreciente, acumulando gran número de observaciones con respecto a los intervalos anteriores.



En el gráfico de densidad, separado por éxito del ataque, vemos que las dos distribuciones son claramente distintas: los ataques fallidos se concentran alrededor de 30-35 puntos, mientras que los exitosos lo hacen alrededor de 65. Aunque se ve una zona de solapamiento entre los 40 y 60 puntos, demuestra que hay una correlación fuerte entre ambas variables.

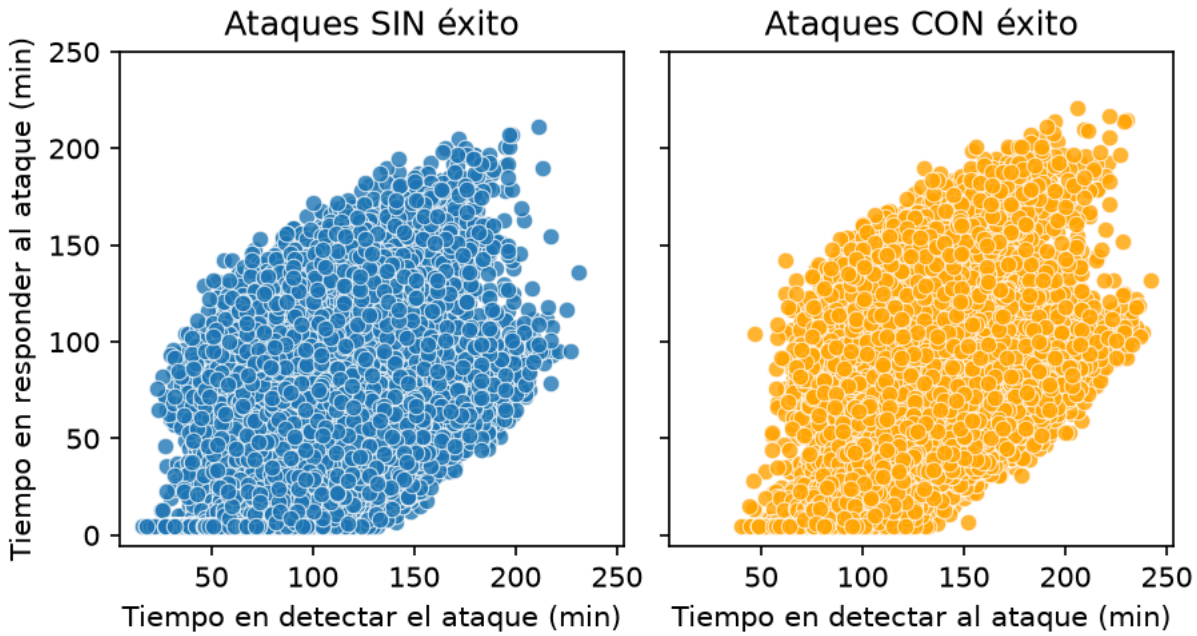
Análisis exploratorio

En este apartado intentaremos analizar y encontrar relaciones entre variables, y en especial su comportamiento con respecto a nuestras variables de interés.

La elección de ellas es por simple sospecha o suposición de que pueden tener una relación interesante para visualizar.

Cada análisis se hace a través de una tabla o gráfica, que intenta responder una pregunta disparadora.

¿Un ataque que tuvo éxito fue más díficil de detectar?



En este gráfico donde cada punto representa una observación, nos muestra la relación entre el tiempo demorado en detectar el ataque (`Detection_Time_Min`), el tiempo demorado en responder al ataque (`Response_Time_Min`), y el éxito del ataque (`Attack_Success`).

En ambos gráficos vemos una gran nube de puntos que parecen tener una relación lineal positiva, pero con una gran varianza. Observamos que no hay datos con muy bajo tiempo de respuesta y alto tiempo de detección ni viceversa, pero la nube es muy gruesa, y si trazaramos la mejor recta posible, habría muchos puntos a una gran distancia.

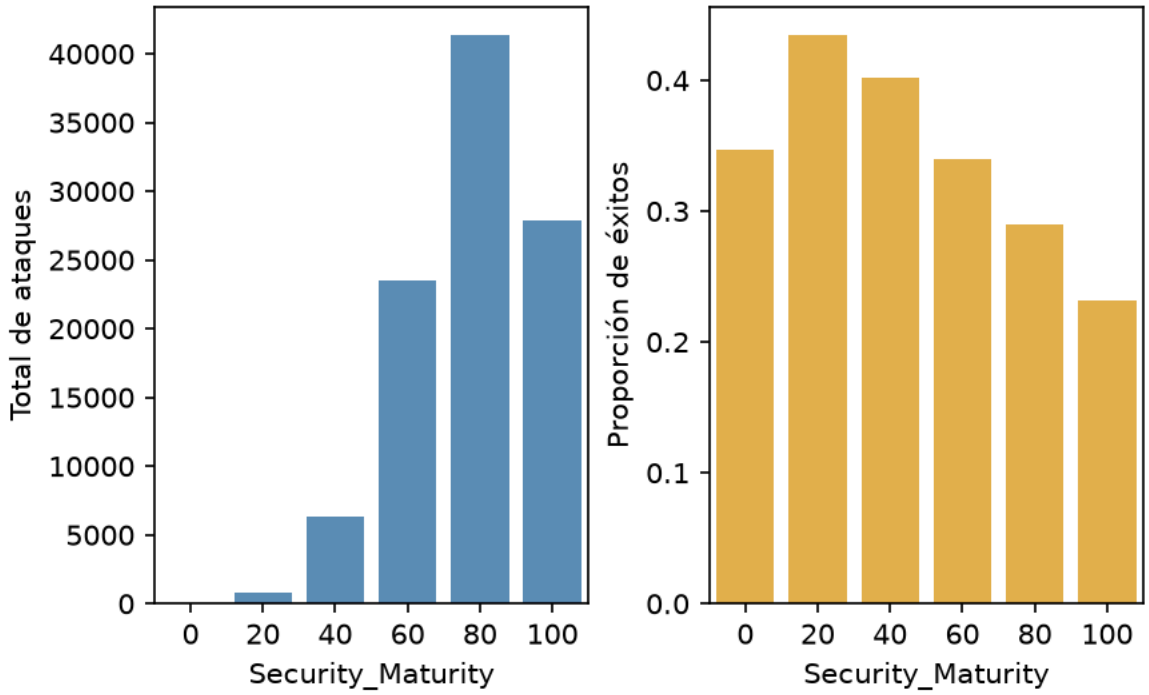
La principal diferencia entre ambos paneles, es que cuando el ataque tuvo éxito, casi nunca la detección fue en menos de 50 minutos.

En conclusión, es muy dificil distinguir si el ataque tuvo éxito o no, en base a estos tiempo, salvo que se haya detectado en menos de 50 minutos, donde ahi sí es mucho más probable que no haya tenido éxito.

¿El desarrollo en seguridad de la empresa evita ataques?

	Security_Maturity	Total_de_ataques	Cantidad_de_exitos	\
0	0	49	17	
1	20	805	350	
2	40	6340	2551	
3	60	23522	8002	
4	80	41379	12010	
5	100	27905	6476	

```
   Proporcion_de_exitos
0              0.346939
1              0.434783
2              0.402366
3              0.340192
4              0.290244
5              0.232073
```

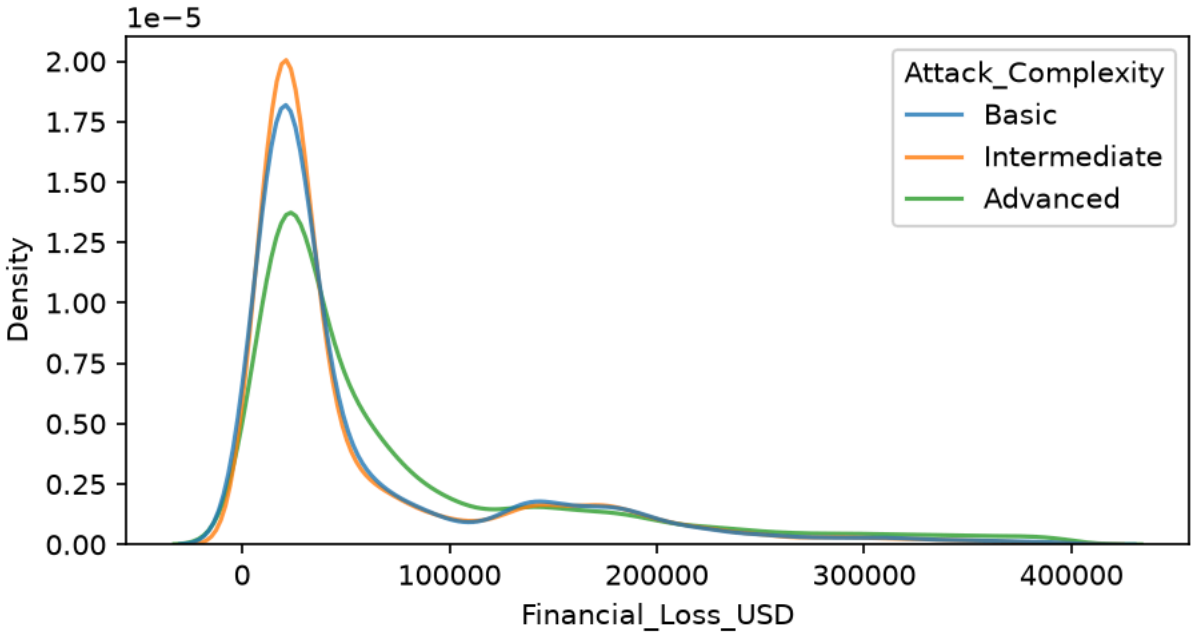


Esta tabla muestra, para cada nivel de madurez de seguridad (`Security_Maturity`, 0-20-40-60-80-100), cuántos ataques recibieron las empresas y qué proporción de ellos tuvo éxito.

En la columna de proporción y en el gráfico se observa lo esperado, a medida que aumenta la madurez de la empresa en temas de seguridad, el porcentaje de ataques en su contra disminuye, estableciendo una relación negativa.

La categoría de `Security_Maturity` igual a 0, probablemente no cumpla con la relación por la baja cantidad de observaciones (49).

¿Un ataque más complejo realiza más daño?




```
Attack_Complexity
Advanced        1207
Intermediate     416
Basic            139
Name: count, dtype: int64
```

La variable `Attack_Complexity` categoriza cada ataque por su nivel de complejidad, en basica, intermedia y avanzada.

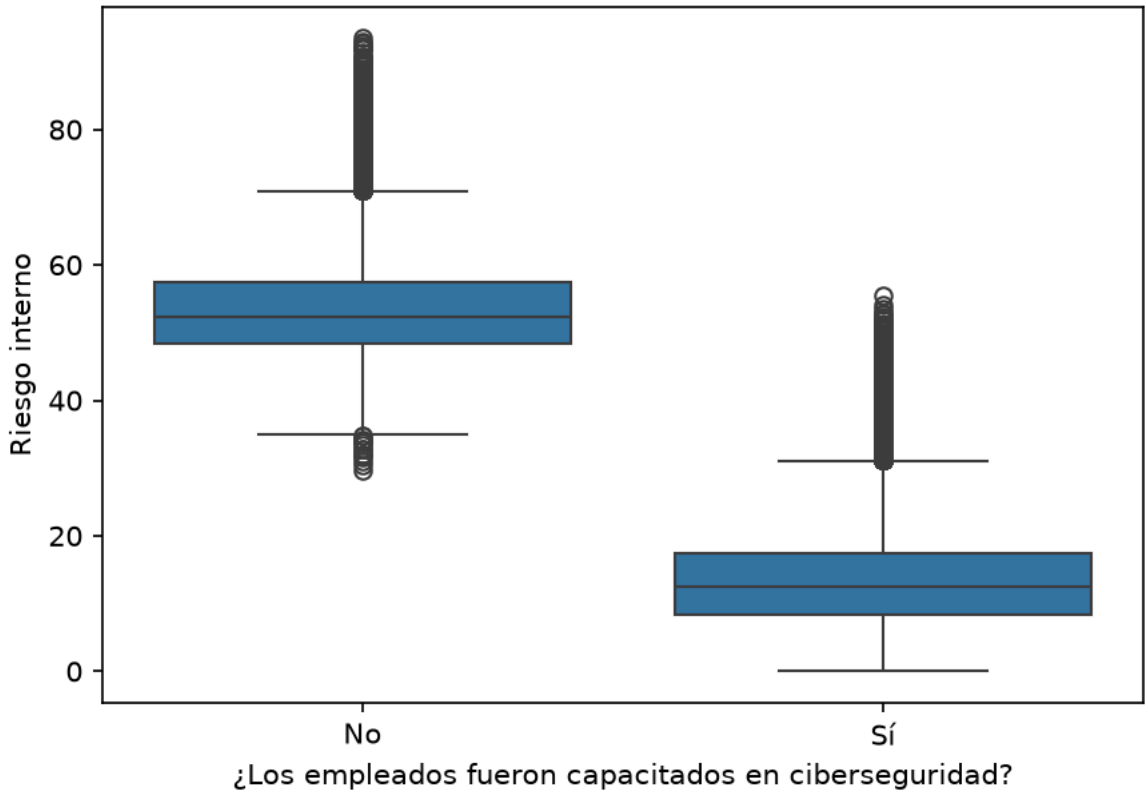
Para el gráfico se filtró `Financial_Loss_USD` en valores menores a 400000 para que se puedan visualizar mejor las curvas y complementamos con una tabla que cuenta la frecuencia de cada categoría, cuando `Financial_Loss_USD` es mayor a 400000.

Observamos en el gráfico de densidad de `Financial_Loss_USD` que las categorías basic e intermediate, tienen una distribución casi idéntica, con casi todos sus datos antes de los 100000 USD, y un leve aumento de la densidad sobre los 150000. A diferencia de la categoría advanced, donde su densidad en los primeros valores es mucho menor, y en la tabla podemos ver que los datos filtrados del gráfico, corresponden en su gran mayoría a esta categoría.

Entonces, podríamos concluir que si un ataque tiene un muy alto costo, es probable que haya sido muy complejo.

¿Capacitar a los empleados disminuye el riesgo?

```
[Text(0.5, 0, '¿Los empleados fueron capacitados en ciberseguridad?'),
 Text(0, 0.5, 'Riesgo interno')]
```



La variable `Insider_Risk` mide entre 0 y 100 el riesgo de ataques por causas internas (empleados descuidados o malintencionados).

El diagrama de caja nos muestra la distribución del riesgo interno para las empresas, separandolas entre aquellas que si capacitaron en ciberseguridad a sus empleados y aquellas que no lo hicieron.

Vemos una clara diferencia entre estas empresas, donde la mediana para las empresas que capacitaron es menor a 20, y las que no es mayor a 50, y ambos diagramas con cajas con poco desvío, y no logran superponerse.Aunque debemos notar que ambas categorías tienan una gran cantidad de outliers.

Si bien esta relación parece bastante notoria, en la realidad la variable del riesgo interno es muy díficil de calcular.

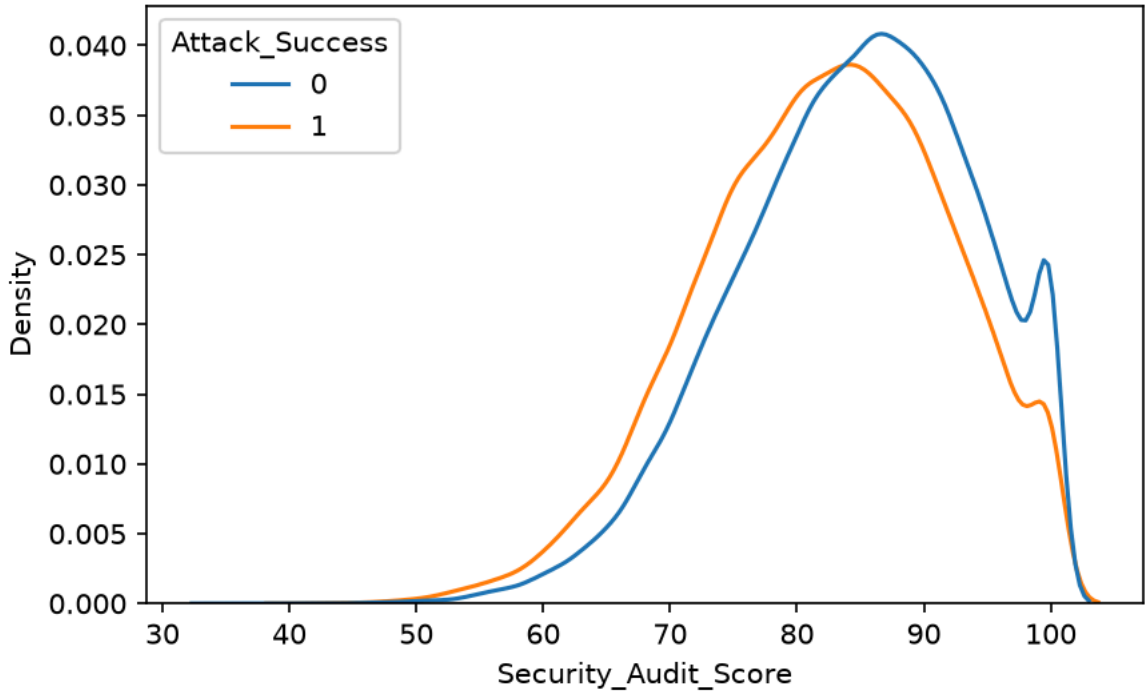
¿El tamaño del equipo de SOC influye en posibles ataques?

cat_SOC	Total_de_casos	Cantidad_de_exitos	Proporcion_de_exitos
Bajo	25036	7395	0.295375
Medio	25046	7334	0.292821
Alto	24943	7394	0.296436
Muy Alto	24975	7283	0.291612

El SOC (Security Operations Center) es el equipo que monitorea y responde a amenazas. Utilizamos la proporción de empleados que formar parte del SOC y clasificamos cada empresa en cuatro categorías según sus cuartiles: Bajo, Medio, Alto y Muy Alto.

En los resultados de la tabla vemos que, al contrario de lo que único quizás podría intuir, no hay ninguna relación entre el tamaño del equipo de SOC y la cantidad de ataques recibidos por la empresa que fueron éxitosos, pues la proporción de éxito del ataque para cada grupo, es practicamente igual que la proporción de todas las observaciones.

¿Quienes tienen mayor puntuación en la auditoria de ciberseguridad reciben menos ataques?



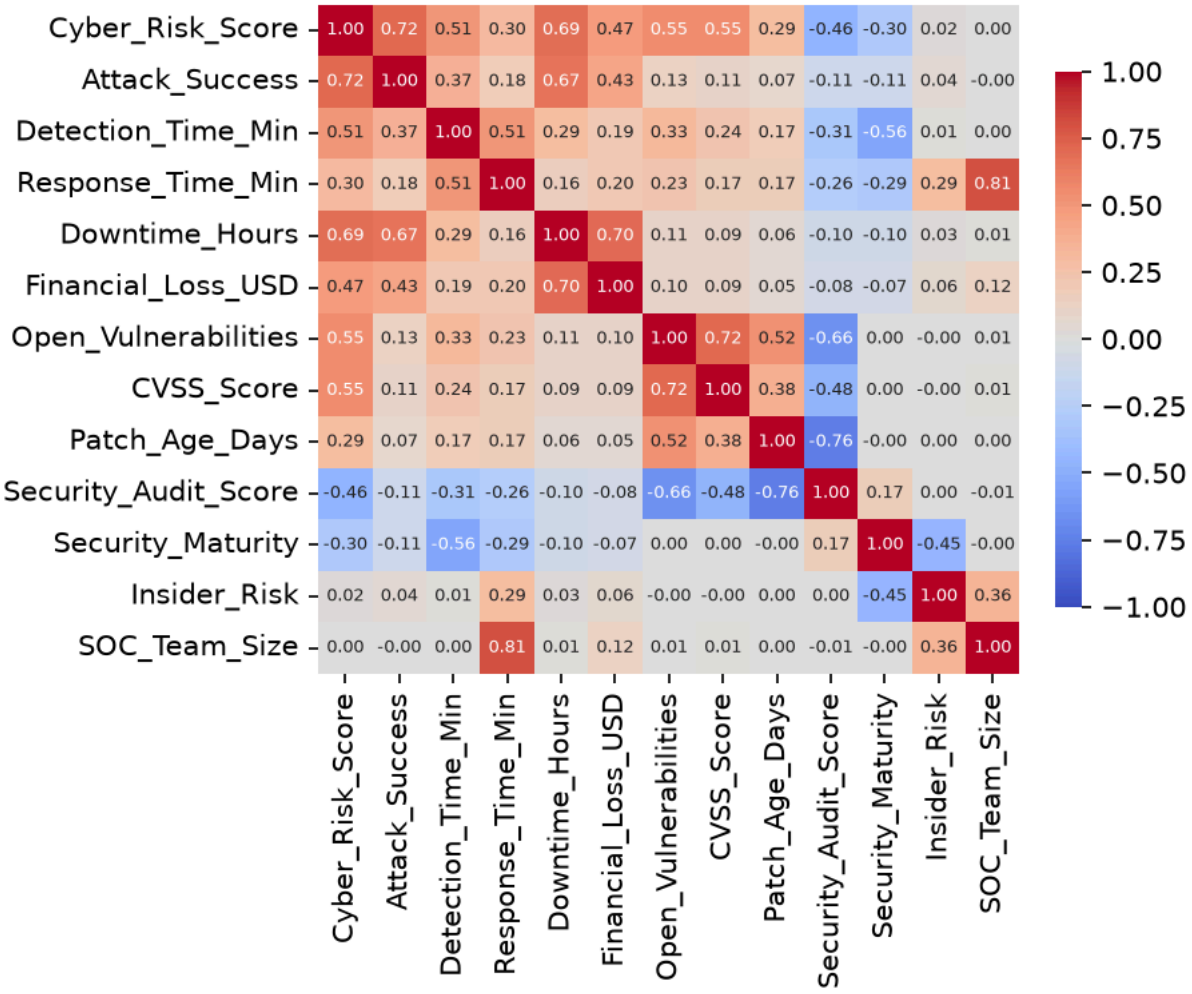
`Security_Audit_Score` es la puntuación de la empresa en auditoría de ciberseguridad (0 a 100).

El gráfico muestra la densidad de esta variable, separada por `Attack_Success`, donde cada curva tiene área igual a uno, para que sean comparables y no afecte el desbalance de los datos.

Observamos que ambas curvas tiene una forma muy parecida, con una asimetría hacia la izquierda, pero con dos pequeñas diferencias. Primeor vemos que la curva en los casos que falló el ataque está corrida algunos valores hacia la derecha (mejores valores de la auditoría), y que su pico es algo más alto que el de la curva naranja. Si bien estas diferencias logran verse claramente en el gráfico, no son los suficientemente grandes para poder distinguir las observaciones.

Correlaciónes entre variables númericas

Para finalizar el análisis exploratorio, realizamos un mapa de calor con las correlaciones entre todas las variables númericas



En este heatmap podemos confirmar relaciones que habíamos analizado y encontrar algunas inesperadas.

Por ejemplo, vemos que si sucedió el ataque y el riesgo tienen una correlación de 0.72, que se observó en las densidades.

El principal descubrimiento es que `SOC_Team_Size` y `Response_Time_Min` son las variables más correlacionadas, pero de manera positiva, es decir, a mayor valor de una variable, mayor valor de la otra, algo bastante contraintuitivo.

Otras variables muy correlacionadas son `Patch_Age_Days` y `Security_Audit_Score`. Con una correlación de −0.76, demuestra que es razonable, cuanto menor la cantidad de días de la última aplicación del parche de seguridad, la empresa tiene una mejor auditoría en seguridad.

Modelado

En esta sección realizaremos dos modelos de machine learning:

1- Clasificación: Predecir si el ataque tuvo éxito, `Attack_Success`, con un árbol de decisión

2- Regresión: Predecir el nivel de riesgo del ataque, `Cyber_Risk_Score`, a través de un bosque aleatorio (random forest)

Sabemos que de las 50 variables, muchas caracterizan las consecuencias del ataque, que se conocen una vez que el ataque sucedió. Por ende, para nuestros modelos de predicción, utilizar estas variables no sería lo más adecuado pues, por ejemplo, si queremos saber si un ataque tuvo éxito, y miramos la variable que mide la pérdidas económicas, está claro que si el valor es alto, el ataque sucedió. Lo más interesante sería predecir estas variables de interés a través de aquellas columnas que caracterizan a la empresa, en aspectos generales y en tanto a la defensa ante ataques, y que nos describen un contexto antes de que suceda cualquier ataque. Asumimos que el ataque 'va a suceder' pero no sabemos como, y queremos predecir que tan factible es que suceda o el riesgo que podría tener.

Para ambos modelos, utilizamos el 75% de los datos para entrenarlo, y el restante 25% para testearlo.

1. Clasificar `Attack_Success` - Árbol de decisión

A términos generales, un árbol de decisión divide y clasifica los datos a través de diferentes preguntas, sobre los valores que toman las variables. En cada pregunta divide en dos grupos, y a ellos los divide en otros dos con otra pregunta. Así sucesivamente hasta clasificar cada observación en una de las dos categorías de la variable a predecir.

Las columnas que utilizamos para entrenar el modelo, son las que clasificamos en el comienzo como características de la empresa, seguridad ante ataques, y posibles vulnerabilidades. Estas variables son iguales para cada posible ataque que podría recibir una empresa.

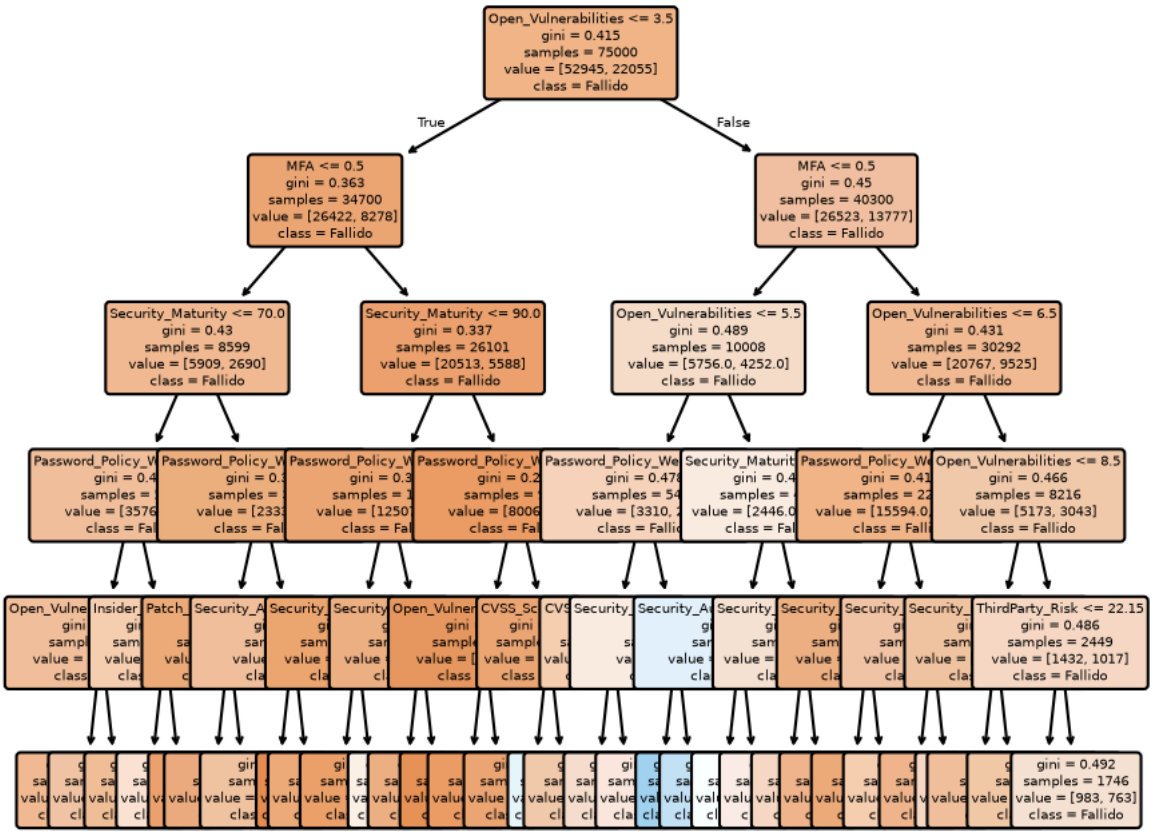
Parámetros utilizados en el árbol:

```
{'ccp_alpha': 0.0,
 'class_weight': None,
 'criterion': 'gini',
```

```
'max_depth': 5,
'max_features': None,
'max_leaf_nodes': None,
'min_impurity_decrease': 0.0,
'min_samples_leaf': 1,
'min_samples_split': 2,
'min_weight_fraction_leaf': 0.0,
'monotonic_cst': None,
'random_state': 123,
'splitter': 'best'}
```

Todos los parámetros tienen su valor por defecto, salvo 'max_depth', la profundidad del árbol, que se le asigno un valor pequeño, únicamente para poder visualizar las decisiones que toma el árbol gráficamente, no por la búsqueda de un mejor resultado.

Gráfico del árbol de decisión:



Si bien no logra visualizarse perfectamente, podemos observar a rasgos generales como se fue creando el árbol. Por ejemplo, la primera decisión que toma es preguntar si

`Open_Vulnerabilities` es menor o igual a 3.5. A todas las observaciones cuya respuesta sea verdadera, las 'envía' al grupo de la izquierda, y al resto a la derecha.

Podemos observar, que cada hoja se pinta de naranja si a ese grupo de observaciones lo clasifica como ataque fallido, y de celeste si lo clasifica como ataque éxitoso. Vemos que la gran mayoría de las hojas son naranjas, esto se debe al desbalance en los datos de `Attack_Success`.

Matriz de confusión del árbol sobre los datos de test:

```
array([[17477,   172],
       [ 7189,   162]])
```

Las filas indican los valores reales y las columnas las predicciones. El valor en la posición (0,0) representa la cantidad de observaciones donde el valor real era 0 (no éxito) y se predijo 0.

Entonces el árbol predijo, en la 25000 observaciones de test, correctamente 17477 ataques como fallidos, y 162 como exitosos. Cometió error en 172 observaciones clasificandolas como éxito, y en verdad era fallido; y en 7189 clasificando como fallido, y era éxito.

Métricas de evaluación:

```
              precision    recall  f1-score   support

           0       0.71      0.99      0.83     17649
           1       0.49      0.02      0.04      7351

    accuracy                           0.71     25000
   macro avg       0.60      0.51      0.43     25000
weighted avg       0.64      0.71      0.60     25000
```

- Accuracy general (0,71): proporción de aciertos totales. Parece aceptable mirandolo por si solo, pero un árbol que solo predice ataque fallido, tiene 70.6% de precisión.
- Recall de la clase éxito (0,02): De todos los ataques exitosos, solo predijo 2% correctamente.
- El F1 de la clase éxito (0,04): muestra lo mismo que antes, al modeo le cuesta mucho detectar correctamente ataques que tuvieron éxito.

Conclusión, el árbol realizado no es bueno clasificando ataques, pues tiende a clasificar prácticamente a todas las observaciones como fallido. Este error se debe en gran parte al desbalance de los datos, y a que no hay fuertes relaciones entre el conjuntos de estas variables y el éxito o no de un ataque.

2. Predecir `Cyber_Risk_Score` - Bosque aleatorio de regresión

En este caso, la variable a predecir es continua, por lo que se denomina un problema de regresión. Se intentará predecir un valor concreto de la variable.

A grandes rasgos, un random forest, es el conjunto de muchos árboles, donde cada uno se entrena y la predicción final es el promedio de las predicciones de todos los árboles. La ventaja está en que

al ser más arboles, el modelo es más robusto, pero se pierde interpretabilidad, pues ya no podemos ver las decisiones que toma el modelo.

En este caso, vamos a utilizar las mismas variables que en el árbol, y le agreamos las que describen el comienzo del ataque. Agregamos las posibles formas que tiene el atacante de introducirse en la empresa.

Los hiperparámetros del bosque se elegieron mediante la validación cruzada, que nos permite evaluar distintas combinaciones de hiperparámetros, pero sin utilizar los datos de test.

Se simularon las siguientes combinaciones, con un CV = 4:

“max_depth”: [5, 10, None] - “max_features”: [0.2, 0.5, 1.0]

En las pruebas de la validación cruzada, se realizaron 100 árboles, pero el bosque final, con la mejor combinación de hiperparámetros, se realizó con 250.

Resultado de la validación cruzada:

```
({'max_depth': 10, 'max_features': 0.5}, np.float64(0.546))
```

Ahora entrenamos un bosque con esos valores de 250 árboles.

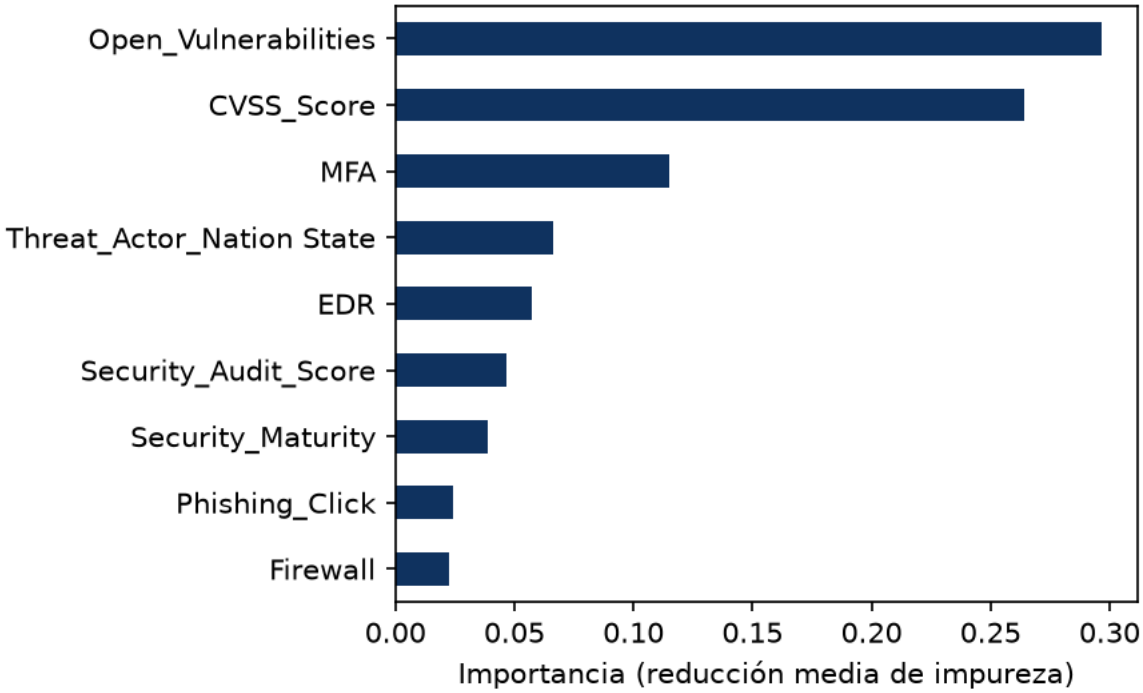
Métricas de evaluación sobre datos de test:

```
MAE     10.69
RMSE    12.70
R2       0.55
dtype: float64
```

- MAE: El promedio de los errores en valor absoluto es de 10.7.
- RMSE: El promedio de los errores al cuadrado es de 12.70. Muy parecido al MAE, castigando más los errores grandes.
- R2: el modelo explica el 55% de la variabilidad del riesgo.

Conclusión, el modelo no termina de ser del todo bueno, pues hay un 45% del riesgo que no logra explicar, y en una escala del 1 al 100, un error mayor a 10 puntos en promedio, no es para nada menor. Demuestra que las variabls utilizadas no tienen una fuerte relación con el riesgo del ataque.

Importancia de las variables para predecir (solo las que superan 0.01):



En términos generales, la importancia mide cuanto contribuye la variable en el modelo.

Vemos que hay dos variables que predominan claramente. `Open_Vulnerabilities` cuenta el número de vulnerabilidades de la empresa sin resolver, y `CVSS_Score` es la puntuación entre 1 y 10 del Sistema Común de Puntuación de Vulnerabilidades, que manifiesta que tan vulnerable es el sistema de seguridad de la empresa.

Comentarios finales:

En este proyecto buscábamos analizar y entender las caracterísitcas de los ciberataques, y las razones por las cuales hace que un ciberataque tenga éxito y qué factores elevan su nivel de riesgo, mirando tanto cómo se lleva a cabo el ataque como la situación de la empresa que lo recibe.

Las principales conclusiones que podemos extraer del analisis exploratorio, son que en general se cumplen las relaciones esperadas. Por ejemplo, que a mayor madurez en seguridad, menor cantidad de ataques, o que a más comlpejo un ataque, mayores consecuencias monetarias contrae. Aunque si hubo algunas excepciones, como que el porcentaje de trabajodores en el equipo de SOC no influye en la cantidad de ataques con éxito.

En cuanto a los modelos, concluimos que no tuvieron un gran rendimiento. Las causas podrían ser los datos desbalanceados, que las variables del dataset no son suficentes, o que realmente es muy complejo predecir si un ataque sucederá solamente observando a la empresa, pues los ciberataques son incidentes bastante impredecibles y que se pueden realizar de muchas maneras.

Como posible línea futura de trabajo, sin dudas que el principal aspecto a mejorar son los datos. Trabajar con datos reales sería mucho más fructífero y nos permitiría obtener conclusiones reales

sobre los ciberataques. También sería interesante utilizar otros modelos de machine learning, o realizar un análisis más exhaustivos en caunto a los parámetros de los modelos realizados, para intentar obtener mejores resultados.

Referencias:

- Link del dataset: Cyber Attack Detection and risk prediction dataset
- En el repositorio de proyecto se encuentra un archivo pdf que contiene la definición de cada una de las variables del dataset.